Seguridad y calidad

Controles implementados

Identidad y sesión

- Contraseñas con Argon2id.
- Access y refresh JWT firmados con pares de claves separados.
- Access token de corta duración y refresh token rotativo.
- Validación viva del principal en cada request protegido: el JWT aporta la identidad y PostgreSQL determina actividad y rol vigente.
- Solo se almacena el hash del refresh token en PostgreSQL.
- Cookie HTTP-only configurable con `Secure`, `SameSite` y dominio.
- Revocación por sesión y cierre de todas las sesiones.
- La desactivación bloquea inmediatamente access tokens vigentes con `SESSION_REVOKED`; una falla al consultar la autoridad produce `AUTHORITY_UNAVAILABLE` y no se confunde con credenciales inválidas.
- El cliente reconcilia `/auth/me` al navegar, recuperar el foco y actualizar el tablero compartido; un `401` limpia la sesión sin pasar por el interceptor de refresh. Los `403` no se reintentan ni disparan un interceptor global: la reconciliación ocurre en esos límites explícitos para evitar ciclos y efectos laterales sobre denegaciones que no implican un cambio de identidad.

API

- Helmet, CORS con allowlist y límite JSON de 1 MiB.
- Rate limiting general y específico para autenticación.
- Validación Valibot de body, params y query.
- Capacidades por rol más políticas de propiedad de la orden.
- Mensajes de autenticación genéricos y manejador uniforme de errores.
- `requestId` para correlación.

Archivos

- Google Drive compartido se usa para el almacenamiento seleccionado en IaC de staging; Drive transmite archivos mediante rutas autenticadas de la API.
- El adaptador de almacenamiento de objetos conserva carga/descarga directa mediante URLs prefirmadas según entorno.
- Validación posterior de existencia, MIME y tamaño.
- Nombres de objeto generados por servidor.
- Fotografías y firmas fuera de PostgreSQL.

- PDFs privados, checksum SHA-256 y errores de generación sanitizados.
- Las respuestas públicas de reporte no exponen `objectKey`.

Integraciones y datos

- Credenciales de Google y del proveedor de almacenamiento solo en servidor.
- Puertos abstraen integraciones externas.
- Timeouts, reintentos y circuit breaker (CLOSED/OPEN/HALF_OPEN) con métricas Prometheus para adaptadores de Sheets y almacenamiento.
- Outbox e idempotencia para efectos externos.
- Concurrencia optimista en órdenes y restricción de asignación activa.
- Auditoría de acciones críticas con snapshots antes/después cuando aplica.
- La gestión de usuarios exige `users:manage`; las actualizaciones administrativas impiden el auto-bloqueo y la desactivación/degradación del último administrador activo. Las actualizaciones serializables protegen la comprobación ante cambios concurrentes.

Roles

Capacidad	Administrador	Técnico
Usuarios y técnicos	Sí	No
Crear/editar/asignar órdenes	Sí	No
Consultar todas las órdenes	Sí	No
Ejecutar orden propia	Sí según endpoints	Sí
Consultar catálogos	Sí	Sí
Reintentar sincronización/reporte	Sí	No
Descargar reporte	Sí	Solo de orden asignada

Las capacidades declaradas son `users:manage`, `technicians:manage`, `orders:manage`, `orders:execute`, `catalogs:read` y `sync:retry`.

Estrategia de pruebas

Nivel	Herramientas	Cobertura principal
Unitario	Vitest	tokens, contraseñas, validación, máquina de estados, especificación de completitud, PDF, resiliencia, cliente web
Integración API	Supertest + Vitest	autenticación, catálogos, administración, permisos, formato HTTP
Integración DB	Prisma + PostgreSQL de prueba	restricciones, concurrencia, unicidad

Nivel	Herramientas	Cobertura principal
Contrato	OpenAPI + pruebas	health, respuestas y referencias
E2E	Playwright	flujos de administrador y técnico
Build estático	TypeScript/Vue TSC/Vite	compatibilidad estricta y bundles

Pipeline mínimo

1. Instalación con lockfile.
2. Formato y lint.
3. Typecheck.
4. Pruebas unitarias e integración.
5. Validación Prisma y OpenAPI.
6. Build de API y web.
7. Escaneo de dependencias e imágenes.
8. Migraciones, despliegue y smoke tests.

Aspectos que requieren política externa

- Rotación y custodia de claves JWT, Google y almacenamiento.
- Retención legal de fotografías, firmas, auditoría y reportes.
- Control de acceso a `/metrics` en el proxy productivo.
- Backups cifrados y pruebas periódicas de restauración.
- Aprobación del logotipo y leyenda de conformidad del PDF.
- Monitoreo y alertas sobre outbox fallido, generación de reportes y capacidad/retención de Drive o del proveedor configurado.